Final Examination Compliance Checklist

Course Code: 20CYS401 — Secure Software Engineering
System: Online Book Review and Recommendation Platform

1. Requirement & Artifact Verification Checklist

- ✓ **Problem Statement Maintained**: Online Book Review and Recommendation Platform preserved across all code and documentation (no unrelated systems or altered domains).
- ✓ **Roles Strictly Preserved**: USER and ADMINISTRATOR (no invented Faculty/Student roles).
- ✓ **Working Application**: Full Flask 3.1 + SQLAlchemy + SQLite application running locally via `wsgi.py`.
- ✓ **Secure Authentication**: Bcrypt password hashing (rounds=12), HttpOnly cookie session management, complete logout session invalidation.
- ✓ **Object-Level Authorization**: Server-side ownership checks on review edit/delete operations (`ReviewService`).
- ✓ **Role-Based Access Control**: `@admin_required` server-side decorator protecting all `/admin/*` routes.
- ✓ **Search & Details**: Parameterized ORM search by title, author, genre; details view with computed average rating.
- ✓ **Ratings & Reviews**: 1–5 integer rating limits, 5–2000 character review limits, unique rating per user constraint.
- ✓ **Personal Reading List**: Private shelf tracking ("want-to-read", "reading", "finished") isolated per user.
- ✓ **Admin Functionality**: Full catalog CRUD and review moderation with mandatory reason recording.
- ✓

Audit Trail: Dedicated `AuditLog` table capturing security events with sensitive credential scrubbing.

- ✓ **Six Connected UI Screens**: All 6 server-rendered templates styled and interconnected with CSRF protection.
- ✓ **Testing Suite**: 23/23 tests passing (unit, integration, authorization, fuzzing, and e2e workflow).
- ✓ **Controlled IDOR Demonstration**: Proved exploitable on `demo/idor-before` branch, proved mitigated on `main` branch with evidence logs.
- ✓ **Security Scanning**: Bandit SAST scan (0 High, 0 Medium) and secret scan executed and logged in `evidence/phase-11/`.
- ✓ **Containerization**: Multi-stage Dockerfile running as non-root user (UID 10001) with healthcheck probe.
- ✓ **Kubernetes**: Namespace, ConfigMap, Secret, Deployment (with `runAsNonRoot: true` and resource limits), and Service manifests.
- ✓ **CI/CD**: GitHub Actions workflow (`.github/workflows/ci.yml`) automating test runs and Bandit security scanning.
- ✓ **Complete Examination Documentation**: All 16 phase documentation files generated in `docs/`.
- ✓ **End-to-End Traceability**: Full traceability registry (`docs/TRACE-REGISTRY.md`) mapping requirements to tests and controls.
- ✓ **Viva & Demo Guides**: Comprehensive quick-start and demonstration guides created (`README.md`, `docs/EXAM-DEMO-GUIDE.md`, `docs/FINAL-EXAMINATION-REPORT.md`).